IDENTITY-AUTHENTICATION-NHI

식별·인증·비인간 신원 NHI

연관 기출 · 128-4-6, 140-1-11

한눈에 이해

누구라고 주장하는지와 그 주장을 어떻게 입증하는지, 어떤 권한을 언제 회수할지를 사람과 소프트웨어 모두에 적용합니다.

정의와 핵심 원리

식별은계정·식별자등으로주체를 구별하는절차이고 인증은 주체가 제시한인증 수단을 검증하는절차입니다. NHI는 서비스·애플리케이션·장치등비인간개체의신원으로, 워크로드신원과장치신원을포함할 수 있습니다.

• 지식기반 비밀번호, 소유기반보안키·토큰, 생체기반 특성은 서로 다른 인증요소입니다. 위치·행동은 맥락·위험신호로이용할 수 있지만독립요소라는분류는 문헌별차이가있습니다. 동일종류비밀두개를쓰는것만으로MFA가 되지않습니다.

• 인증 요구는 도청·재전송·피싱·온라인추측·복구 경로·세션 탈취와 등록·변경·폐기를 포함합니다. 생체정보는 변경이 곤란하고 확률적오류가 있어단독비밀처럼취급하지 않습니다. 강한인증뒤세션과 인가도 보호해야합니다.

• NHI는 API 키·인증서·서비스 계정·관리형신원등으로자원에 접근합니다. 수량·소유자불명·장기비밀·과다 권한·CI로그 노출·폐기누락이취약점입니다. 목록·책임자·짧은수명 토큰·워크로드연합·최소 권한·회전·사용감시·자동폐기로 통제합니다.

구조·비교·판단

구분	핵심 원리	적용·한계
사람신원	직원·고객·사용자	MFA·접속맥락·퇴사회수
워크로드신원	앱·배치·컨테이너	토큰·역할·실행 환경 검증
장치신원	서버·IoT·단말	인증서·보안상태·등록 폐기

적용 예제

CI 파이프라인 자격증명

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 배포 작업에 운영 환경 접근필요

1. 저장소에장기관리자 키를 두지않고신뢰된실행 주체가 짧은토큰을 받게합니다.
2. 대상 환경과 브랜치등신뢰 조건을 검증합니다.
3. 배포에 필요한 권한만 부여하고 세션·변경을 기록합니다.
4. 프로젝트종료시신원·연합관계·권한을 회수합니다.

결과·해석: 비인간접근도 생성부터폐기까지 책임을 추적합니다.

전제·주의: 비밀번호 정책·보안등급은적용 표준과 업무 요건별확인이 필요합니다.

답안 골격과 혼동 방지

식별·인증·인가 → 인증요소비교 → 생애주기 요구 → NHI 취약점 → 워크로드예

- API 키를 사용자 비밀번호보다 덜민감하게보지않습니다.
- 생체값이 완전히정확하고 회수가 능하다고하지 않습니다.

내용을 가리고 회상

1. 식별자와인증비밀의차이는무엇입니까?
2. NHI의 소유자를 정해야 하는이유는무엇입니까?
3. 같은 종류두인증 값은 왜MFA가 아닐수 있습니까?

적용 기준과 근거

NIST800-63B-4(2025-07), Microsoft신원공식 문서.기출의4가 지유형분류원출처미확인;위치·행동을 독립NIST요소로사칭하지 않음.

내용 검토 상태: 부분 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- NIST SP800-63B-4 Authentication - NIST; 2025-07; 확인 2026-11-05.
- Workload identities overview - Microsoft; 상시 문서; 확인 2026-11-05.